



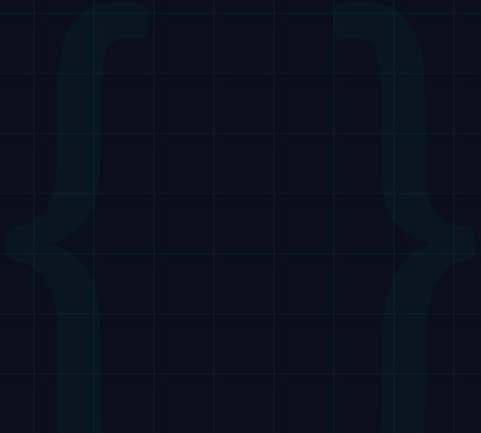
Scattered Spider and the MGM Resorts Breach

A Case Study in Modern Social Engineering



Roberto Reade

CSEC 645 — Social Engineering



INTRODUCTION TO SCATTERED SPIDER

Scattered Spider Prioritizes Human Trust Over Technical Exploits Exploits

- > Defining the Threat: Scattered Spider is a dangerous cyber threat group that prioritizes social engineering over software exploits.
- > Core Philosophy: Their attacks target human trust rather than just technology — people are the vulnerability.
- > Significance: The group gained global notoriety following the September 2023 breach of MGM Resorts International.

\$100M

APPROXIMATE COST OF
MGM RESORTS BREACH

THREAT ACTOR PROFILE

An Informal but Highly Effective Network of Young, English-Speaking Attackers

IDENTITY

An informal network of mostly young, English-speaking individuals that emerged in early 2022.

MOTIVATIONS

Primarily financial — engaging in data theft, extortion, and ransomware deployment.

OPERATIONS

Communicate via Telegram and Discord; tracked by security firms under names: UNC3944, Octo Tempest, and Muddled Libra.

PARTNERSHIPS

Frequently partner with ransomware-as-a-service (RaaS) groups like ALPHV/BlackCat to encrypt victim systems.

THE EVOLUTION OF SCATTERED SPIDER

From SIM-Swapping Telecom Targets to High-Value Enterprise Attacks

PHASE	PERIOD	FOCUS
Phase 1	Early 2022	Targeted telecom companies for SIM-swapping and cryptocurrency theft
Phase 2	Mid–Late 2022	"Oktapus" campaign — mass SMS phishing against 130+ organizations
Phase 3	2023–Present	Shift to high-value enterprises; exploiting cloud identity systems

> Accountability: Notable arrests include alleged leader Tyler Buchanan ("TylerB") in Spain and Noah Urban ("Sosa") in Florida.

SOCIAL ENGINEERING — RECONNAISSANCE

Attackers Map the Human and Technical Landscape Before Striking

[01] Target Selection

Using LinkedIn to identify real employee names, job titles, and their managers.

[02] System Probing

Testing Self-Service Password Reset (SSPR) systems to discover available recovery options.

[03] Infrastructure Mapping

Identifying third-party IT vendors and the target's cloud identity setup.

Reconnaissance transforms publicly available information into a precise attack attack blueprint.

THE ATTACK — GAINING ENTRY

Four Techniques Exploit Human and Authentication System Weaknesses

- > **VISHING** Calling the IT help desk, impersonating an employee using LinkedIn data, and requesting an MFA or password reset.
- > **MFA FATIGUE** Bombarding victims with push notifications until they accidentally approve access.
- > **SIM SWAPPING** Hijacking a victim's phone number to intercept SMS authentication codes.
- > **SSPR ABUSE** Replacing recovery phone numbers with attacker-controlled ones to trigger unauthorized resets.

MOVING THROUGH THE NETWORK

One Compromised Identity Becomes a Master Key Across the Enterprise

☐ SSO LATERAL MOVEMENT

Leveraging Single Sign-On (SSO) to access dozens of systems with a single compromised identity.

☐ PRIVILEGE ESCALATION

Assigning admin roles to compromised accounts and creating hidden administrator accounts to maintain control.

☐ DEFENSE EVASION

Routing traffic through VPNs or Starlink; monitoring victim Slack/Teams channels to track the incident response team in real time.

ANALYSIS OF EXECUTION AND IMPACT

High-Profile Incidents Demonstrate the Group's Reach and Financial Damage

INCIDENT	YEAR	IMPACT
Riot Games	2023	Source code stolen and \$10 million ransom demanded
Caesars Entertainment	2023	65 million records compromised and \$15 million ransom paid

MODERN TRENDS (2026)

Recent focus has shifted to SaaS data stores and VMware ESXi environments using sophisticated vishing techniques.

DEEP DIVE — THE MGM RESORTS ATTACK

A Single LinkedIn Search and One Phone Call Brought Down a \$100M Empire

WHY MGM?

Over 30 hotel/casino properties with highly digitized systems — room keys, slot machines, and guest apps.

EXECUTION — STEP BY STEP

01

RECON

Identified an MGM employee on LinkedIn.

02

THE CALL

Called the IT help desk, impersonated that employee, and convinced the the agent to reset MFA.

03

TAKEOVER

Used Okta admin access to to escalate privileges into Microsoft Azure.

04

ACTION

Encrypted approximately 100 VMware ESXi servers and exfiltrated 6 TB of data.

THE OUTAGE TIMELINE

A Cascading Failure Across All MGM Properties Over Ten Days

DATE	EVENT
Sept 8	Attackers breach MGM following the help desk call
Sept 10	Widespread outages begin; ransomware encrypts servers
Sept 12–13	Slot machines offline, digital room keys fail, reservations down across all properties properties
Sept 20	Systems finally restored

IMPACT ASSESSMENT

The Breach Inflicted Financial, Operational, and Legal Damage at Scale

FINANCIAL

\$84 million in lost Q3 revenue, \$10 million in legal fees, and \$40 million committed to IT upgrades.

OPERATIONAL

Total disruption of mobile apps, restaurant systems, and casino floor operations across all properties.

DATA & LEGAL

Millions of customers affected; multiple lawsuits filed; investigations launched by the FTC and Nevada Gaming Control Board.

DEFENSIVE EVALUATION — WHAT MGM DID WRONG

Three Critical Failures Enabled a Preventable Catastrophe

01

HELP DESK FAILURES

No strong identity verification protocol — an employee's name and employer name alone were sufficient to reset admin MFA.

02

ARCHITECTURAL WEAKNESS

SSO scope was too broad; VMware ESXi served as a single point of failure for the entire infrastructure.

03

NEGLECT

MGM had previously received and ignored security warnings issued directly by Okta.

DEFENSIVE EVALUATION — WHAT MGM DID RIGHT

Containment, Collaboration, and Ethical Resolve Defined MGM's Response

01

CONTAINMENT

Rapidly shut down critical systems to stop the attack's spread and limit further damage across the enterprise.

02

COLLABORATION

Immediately engaged third-party cybersecurity firms and coordinated closely with law enforcement agencies.

03

ETHICS & RESILIENCE

Refused to pay the ransom and committed \$40 million to comprehensive security improvements and IT upgrades.

ETHICAL IMPLICATIONS OF THE INCIDENT

The Human Cost: Privacy, Trust, and Systemic Vulnerability

> PRIVACY

Exposure of personal data for millions of guests, leading to long-term identity theft risks and a fundamental violation of consumer privacy.

> TRUST

Attackers weaponized the helpful nature of IT support staff, turning a service-oriented culture oriented culture into a critical security liability.

> SYSTEMIC

The breach demonstrated how a single human error can cascade into a massive societal and economic disruption across a global enterprise.

> DILEMMA

The ethical conflict of ransom payments: balancing immediate business recovery against the against the long-term funding of global criminal networks.

RECOMMENDATIONS — HARDENING AUTHENTICATION

Stronger Identity Verification Must Be the First Line of Defense

[POLICY 01] HELP DESK PROTOCOL

Require manager approval and video verification for any MFA reset requests.

[POLICY 02] MFA UPGRADE

Switch all privileged accounts to FIDO2 hardware security keys — phishing-resistant by design.

[POLICY 03] CLOUD IDENTITY CONTROLS

Block SSPR phone number changes without mandatory secondary verification.

RECOMMENDATIONS — ARCHITECTURE AND DETECTION

Zero Trust, Proactive Detection, and Vendor Accountability Close the Gaps

ZERO TRUST ARCHITECTURE

Enforce least-privilege access and micro-segment the network to limit lateral movement.

PROACTIVE TESTING

Conduct regular phishing simulations and tabletop exercises to prepare staff.

DETECTION & ALERTING

Set alerts for unusual SSPR attempts, off-hours MFA registrations, and deletions of access policies.

VENDOR RISK MANAGEMENT

Apply the same internal verification standards to all third-party vendors.



Thank You

Roberto Reade

CSEC 645 — Social Engineering

